A red check. The merge still went through.

Our test: one test and one key scan on every pull request.

OUR TEST

Two asks, in the step 17 repository.

ASK 1

"Add a test test_changes.py that fails if the three lines of python3 changes.py change. Add a GitHub Actions workflow that runs pytest and gitleaks on every pull request. Put it on a branch and open a pull request."

ASK 2

"Merge this pull request. Then make the two checks required, so nothing can merge to main while a check is red."

Then one bad change: rank by percent, not by pallets. Interactive Claude Code, accept edits mode.

THE RESULT

Private warns. Public can block.

	PRIVATE, GITHUB FREE	PUBLIC, GITHUB FREE
Checks run	Yes	Yes
Required checks	Refused	On
Merge on red	Went through	Refused
Merge on red, as admin (test PR)	Not needed	Refused

The merge block comes from required checks, with no exception for admins, that Claude set up on our ask. The public copy holds only made-up data. We did not test GitHub Pro.

WHAT GITHUB SAID

Two answers, word for word.

```
# private: make the checks required
Upgrade to GitHub Pro or make this repository
public to enable this feature.

# public: merge with a red check, the API
Required status check "pytest" is failing.
```

On your own: gh pr view <number> --json mergeStateStatus. Do not guess, and do not merge it.

WHAT WE SAW

A red test can go green the wrong way.

- After the red check, the next suggestion in the prompt was: "update the test to the new output".
- A red test goes green if you change the test. Read every change to a test.
- It changed the README too: "even though you only named changes.py".

THE KEY SCAN

One made-up key, two answers.

- **Public copy:** GitHub stopped the push: "Push cannot contain secrets".
- **Private repository:** the push went through, and gitleaks went red. GitHub did not mark it blocked.
- A red scan means the key already reached GitHub. Closing the pull request does not remove it. With a real key: change the key.

MY OWN SETUP

Five scanners. One required check.

- Our main repository runs five scanners on pull requests: gitleaks, semgrep, bandit, pip-audit and zizmor.
- New findings fail, for pip-audit only when a dependency file changed. Findings already in the baseline do not.
- Anthropic on automated security reviews: they "should complement, not replace" your own practices and manual reviews.

FREE FILES

Get the files. Free.

→ The test and the workflow

→ The cheat sheet, with the asks word for word

→ How to see if a red check blocks or only warns

→ A check before you merge

On my profile, under Featured: AI Starter Kit, step 19. Save this post.

Next: one agent, any model.